LABORATUVAR 5 · EFO MAKİNA · BESLEME BANDI & SARSAK

SBOM / CVE / Patch

Çıktı: Vulnerability Decision

AD SOYAD	GRUP	EVİDENCE PACK	MAKİNE
Yağız Enes Doğan	Gündüz - B	EP 09 · 10 · 11	Efo Makina · Besleme Bandı & Sarsak (Titreşimli Konveyör)

Bağımsız akademik çalışmadır; Efo Makina ile bağlantısı yoktur. Analizin birçok kısmı varsayıma dayanır ve gerçek ürünün emniyet durumu hakkında bir iddia değildir.

Kavram: SBOM = yazılım malzeme listesi · **CVE** = açığın kayıt numarası · **CVSS** = ciddiyet (0–10). Bir CVE sizi etkiler mi? Üç şart: **bileşen var**, **sürüm etkileniyor**, **açık ulaşılabilir**.

Efo bağlamı: Efo bir SBOM yayınlamıyor; PLC, HMI ve invertör markaları da bilinmiyor (V2, V3). SBOM bu yüzden LAB 2'deki varlık listesinden kuruldu; sürümler varsayımdır (V16). Föydeki kayıt (Component X 2.4, CVSS 9,8) olduğu gibi kullanıldı; etkilenen sürüm aralığı föyde olmadığı için "2.5 öncesi etkilenir" kabul edildi (V17). Karşılaştırma için iki gerçek kayıt eklendi: S7-1200 için **CVE-2024-47100** ve S7-1200'ü **etkilemeyen** SSA-688146 (Makine Profili D5, D6). Ulaşılabilirlik, LAB 4'teki saldırı grafından hesaplandı.

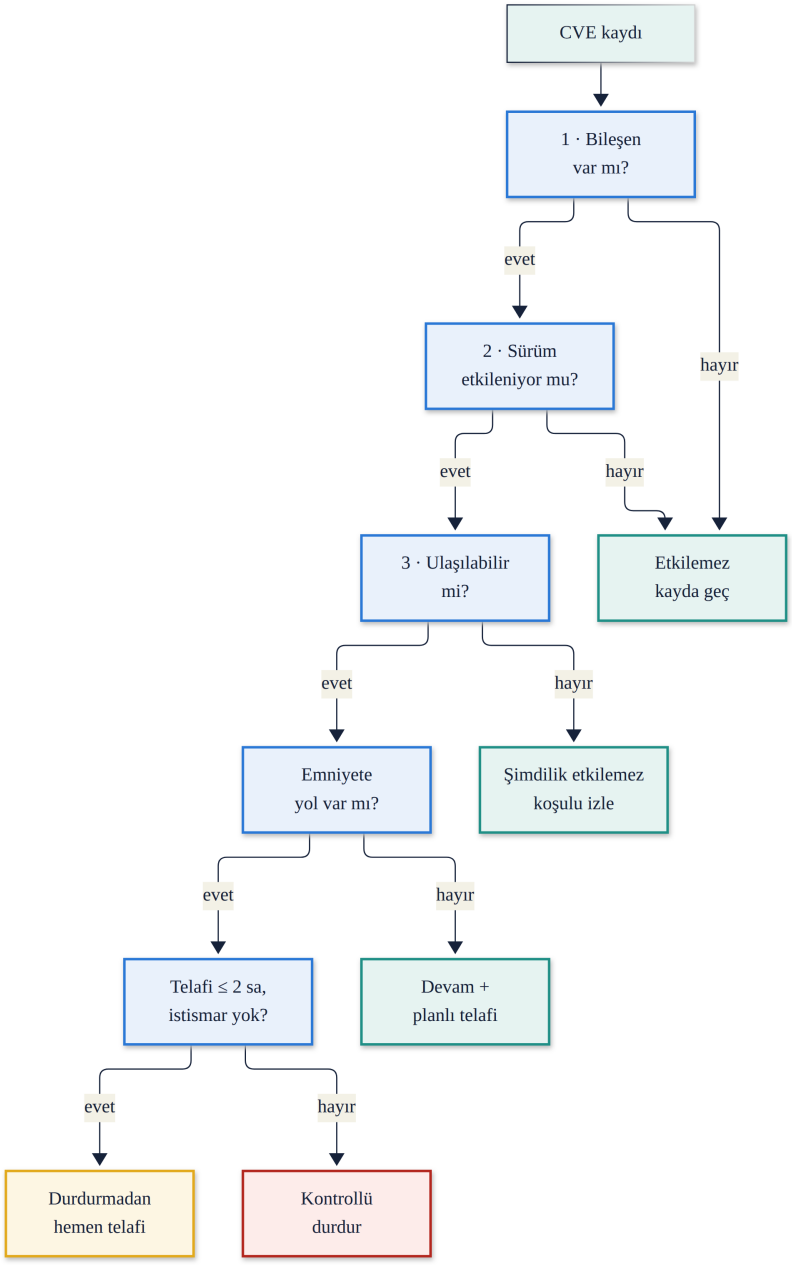
Verilen zafiyet kaydı

Alan	Föy	Efo karşılığı
Bileşen	Component X (PLC firmware kütüphanesi)	Hat PLC'sinin firmware'indeki bir kütüphane (V3, V16)
Sürüm	2.4	2.4
CVE	CVE-XXXX-XXXX	Föydeki temsilî kayıt
Önem	Critical (CVSS 9,8)	CVSS 9,8 tipik olarak ağdan, kimlik doğrulamasız istismar demektir [Y24] SEKTÖR-TİPİK
Yama	Mevcut	2.5 kabul edildi (V17)

SBOM (varsayım). Her bileşen, LAB 4 saldırı grafında bir düğüme bağlandı. Böylece "açık ulaşılabilir mi?" sorusu grafın üzerinde hesaplanabiliyor [Y23] VARSAYIM.

Bileşen	Sürüm	LAB 4 düğümü	Yazılım içerir
PLC firmware (S7-1200 sınıfı)	4.5	PLC	evet
Component X (PLC firmware kütüphanesi)	2.4	PLC	evet
Operatör paneli yazılımı	17.0	HMI	evet
Uzak masaüstü aracı (HMI'da)	15.0	HMI	evet
Bant invertörü firmware + WLAN modülü	3.2	Bant invertörü	evet
4G/VPN router firmware	7.1	4G/VPN router	evet
Emniyet rölesi (kablolu, yazılımsız)	-	Emniyet rölesi / Safety PLC	hayır

Görev — karar akışı



Şekil 1 — Karar akışı. CVSS yalnızca bir girdi; kararı üç şart, emniyete yol ve telafi süresi belirler.

1 Bu CVE sizi gerçekten etkiliyor mu? (üç şartı kontrol edin)

Mevcut (varsayım) mimaride: evet, üç şart da sağlanıyor.

1. **Bileşen var:** Component X, PLC firmware'inin içinde (SBOM) VARSAYIM.
2. **Sürüm etkileniyor:** 2.4 < 2.5 (ilk düzeltilmiş sürüm) VARSAYIM (V17).
3. **Açık ulaşılabilir:** Düz ağda PLC'ye internetten (sürekli açık router), uzak masaüstü aracından, USB'den ve varsayılan parolalı HMI'dan ulaşılıyor (LAB 4.1).

Hedef mimaride: yalnızca içeri girildiği kabul edilirse. Saldırgan VPN ve MFA'yı aşarsa jump server → HMI → PLC yolundan PLC'ye ulaşıyor. Üçüncü şart da ancak bu durumda sağlanıyor.

Karşılaştırma için iki gerçek kayıt aynı akıştan geçirildi:

Kayıt	CVSS	Mimari	Bileşen var	Sürüm etkilenir	Ulaşılabilir	Emniyete yol	Karar
CVE-XXXX-XXXX (Component X)	9,8	Mevcut (varsayım)	✔	✔	✔	✔	Durdurmadan hemen telafi; yama test sonrası

Kayıt	CVSS	Mimari	Bileşen var	Sürüm etkilenir	Ulaşılabilir	Emniyete yol	Karar
CVE-XXXX-XXXX (Component X)	9,8	Hedef, içeri girilmiş kabulü	✔	✔	✔	X	Devam + planlı telafi; yama bakım penceresinde
CVE-2024-47100 (S7-1200)	7,1	Mevcut (varsayım)	✔	✔	✔	✔	Durdurmadan hemen telafi; yama test sonrası
CVE-2024-47100 (S7-1200)	7,1	Hedef, içeri girilmiş kabulü	✔	✔	X	X	Devam: CVE bu hatta etkili değil
SSA-688146 (S7-1500 / ET 200SP)	9,1	Mevcut (varsayım)	X	X	X	—	Devam: CVE bu hatta etkili değil
SSA-688146 (S7-1500 / ET 200SP)	9,1	Hedef, içeri girilmiş kabulü	X	X	X	—	Devam: CVE bu hatta etkili değil

Ulaşılabilirlik, LAB 4'teki giriş noktalarından (internet, uzak araç, USB, yerel HMI, Wi-Fi) bileşenin düğümüne açık bir yol olup olmadığıdır. Hedef sütununda saldırganın VPN ve MFA'yı aştığı kabul edildi.

- **CVE-2024-47100** yalnızca PLC web sunucusu açıksa ulaşılabilir. Hedefte web sunucusu kapalı olduğundan sürüm etkilense bile üçüncü şart düşüyor [Y12].
- **SSA-688146**'nın CVSS'i 9,1, ama S7-1500 ve ET 200SP içindir. Bu yüzden ilk şartta eleniyor [Y14]. Yüksek CVSS, kayıt sizi etkilemediği sürece bir şey ifade etmez.

2 Üretimi hemen durdurur musunuz? Neden / neden değil?

Hayır, kendiliğinden durdurmayız. Ama karar mimariye bağlı ve bir durdurma koşulu var.

- **CVSS kararı vermez.** CVSS, açığın genel ciddiyetini ölçer; bu hatta neye yol açacağını söylemez [Y24]. Aynı 9,8'lik kayıt, mevcut ve hedef mimaride farklı karar alıyor (test: `test_cvss_tek_basina_karari_belirlemez`).
- **Mevcut mimaride:** PLC'den emniyet fonksiyonuna yol var (LAB 4: acil stop PLC mantığında). Yani bu açık, emniyeti bozabilen bir açık. Yine de dört telafi edici önlem 1,5 saatte açığı ulaşılamaz kılıyor (Q5). Karar: **durdurmadan hemen telafi**.
- **Durdurma koşulu:** Aktif istismar belirtisi varsa hat **kontrollü durdurulur**. Örnekler: kayıt CISA KEV kataloğunda [Y25], PLC CRC'si referanstan farklı (LAB 6), ya da telafi 2 saatte bitirilemiyor. Bu kural kodda ve testte var (`test_bagimli_emniyette_istismar_belirtisi_varsa_hat_kontrollu_durur`).
- **Hedef mimaride:** PLC ele geçirilse bile emniyet fonksiyonuna yol yok (LAB 4: 0 yol). Açık bir **kullanılabilirlik** riski, emniyet riski değil. Karar: **devam + planlı telafi**, yama bakım penceresinde.

3 Yamayı doğrudan mı uygularsınız, önce test mi? Nerede test?

Önce test. PLC firmware yaması, hattı çalıştıran yazılımı değiştirir. Doğrudan uygulamak; haberleşme kaybına, proje uyumsuzluğuna ya da hattın açılmamasına yol açabilir [Y26] SEKTÖR-TİPİK.

- **Nerede:** Aynı firmware ve aynı projeyle kurulmuş **yedek CPU'lu bir test tezgâhında**. Efo'nun atölyesinde FAT düzeni ya da müşteri sahasında hattan ayrı bir pano olabilir VARSAYIM.
- **Sıra** (kod: `yama_adimlari`):
  1. Test tezgâhında yamayı uygula.
  2. Normal fonksiyon testleri: start/stop, yongalama interlock'u, haberleşme.
  3. Validasyon etkileniyorsa emniyet testleri: SF1–SF4 + durma süresi ölçümü (Q4).
  4. Bakım penceresinde hatta uygula; eski sürümün yedeği hazır olsun.
  5. Yeni konfigürasyonun CRC'sini referans olarak kaydet (LAB 6'da bu referansla karşılaştırma yapılıyor).

4 Bu yama bir safety validation'ı etkiliyor mu? Nasıl anlarsınız?

Mevcut mimaride evet, hedef mimaride hayır. Anlamak için dört kontrol:

1. **Bileşen emniyet zincirinde mi?** SBOM'da emniyet rölesi ya da Safety PLC'nin firmware'i değişiyorsa validasyon her zaman etkilenir (`test_emniyet_rolesi_degisikligi_her_mimaride_validasyon_gerektirir`).
2. **Bileşenden emniyet fonksiyonuna bir bağımlılık yolu var mı?** Bu, LAB 4 grafından hesaplanıyor. Mevcutta PLC → SF1 yolu var: yama, acil stopun davranışını değiştirebilir. Hedefte yol yok: normal PLC'nin yaması emniyeti etkilemez.

3. **Üreticinin sürüm notları:** Yama emniyetle ilgili bir fonksiyonu (STO, SS1, emniyet haberleşmesi) değiştiriyor mu?
4. **Emniyet programının ve parametrelerinin CRC'si:** Yamadan önce ve sonra aynı mı?

Etkileniyorsa SF1–SF4 fonksiyon testleri ve durma süresi ölçümü tekrarlanır. Bu, LAB 4 QE2'deki bulgunun sayısal karşılığıdır: **bağımsız emniyet, yama döngüsünü hızlandırır**, çünkü her PLC yaması yeniden doğrulama gerektirmez [R61] ÇIKARIM.

5 Yama mümkün değilse compensating control (telafi edici önlem) ne olur?

Telafi edici önlem, açığı kapatmaz; **üçüncü şartı** (ulaşılabilirlik) bozar. Model, açığı ulaşılamaz kılan en kısa süreli önlem kümesini bütün alt kümeleri deneyerek buluyor VARSAYIM (V18):

Mimari	En kısa telafi kümesi	Süre	Telafiden sonra ulaşılabilir mi?	Validasyon etkilenir mi?
Mevcut (varsayım)	T1: Uzak destek router'ının bağlantısını fiziksel olarak kesmek T4: Pano ve HMI USB portlarını kilitlemek T5: HMI varsayılan parolasını değiştirmek T6: HMI'daki uzak masaüstü aracını kaldırmak	1,50 sa	hayır	**evet**
Hedef, içeri girilmiş kabulü	T7: Yama bitene kadar uzak bakım oturumuna (C1) tesis onayı vermemek	0,10 sa	hayır	hayır

Telafi için kabul edilen azami süre: 2,0 saat. Aktif istismar belirtisi varsa ve bileşenden emniyet fonksiyonuna yol varsa karar doğrudan "Kontrollü durdur; telafi ya da yama sonrası yeniden doğrula" olur.

- **Mevcutta:** Dört önlem gerekiyor, çünkü PLC'ye dört ayrı giriş noktasından ulaşılıyor. T3 (WLAN) bu kümede yok; Wi-Fi yalnızca invertöre ulaşıyor, PLC'ye değil. Ama invertör parametreleri için ayrıca gerekli (LAB 3, S1).
- **Hedefte:** Tek önlem yetiyor: yama bitene kadar uzak bakım oturumuna onay vermemek. Bu, LAB 4'ün "varsayılan kapalı" ilkesinin doğrudan bir faydası.
- **Ek olarak** SEKTÖR-TİPİK [Y26]:
  - Kullanılmayan servisleri kapatmak (PLC web sunucusu → CVE-2024-47100'ü de kapatır).
  - C3 güvenlik duvarında PLC'ye yalnızca izin listesindeki portları açmak.
  - PLC'ye giden trafiği izlemek ve anormal yazma isteklerinde alarm üretmek.
  - Kaydı KEV kataloğunda izlemek; istismar başlarsa karar "durdur"a döner.

Kanıt: simülasyon (LAB 5)

Eğitim amaçlı modeldir; gerçek bir zafiyet taraması ya da emniyet doğrulaması değildir. SBOM ve sürümler varsayımdır.

Ne gösterildi?

- Üç şart koddan hesaplandı; ulaşılabilirlik LAB 4 saldırı grafından geliyor.
- Karar, CVSS'e göre değil, mimariye göre değişiyor.
- Telafi planı açığı gerçekten ulaşılamaz kılıyor ve 2 saatlik sınırın içinde kalıyor.
- Validasyon ihtiyacı, bileşenden emniyet fonksiyonuna yol olup olmamasıyla belirleniyor.

Test sonuçları:

#	Test (dosya)	Sonuç
1	`test_surum_karsilastirmasi_sayisaldir` (test_lab5_vuln)	✔ geçti (6/6)
2	`test_foydeki_kayit_mevcut_mimaride_uc_sarti_da_saglar` (test_lab5_vuln)	✔ geçti
3	`test_sbomda_olmayan_urun_cvss_yuksek_olsa_da_etkilemez` (test_lab5_vuln)	✔ geçti
4	`test_web_sunucusu_kapaliysa_csrf_acigi_ulasilamaz` (test_lab5_vuln)	✔ geçti
5	`test_her_sbom_bileseni_saldiri_grafinda_bir_dugume_baglidir` (test_lab5_vuln)	✔ geçti
6	`test_telafi_onlemleri_mimarideki_kosullari_kapatir` (test_lab5_vuln)	✔ geçti
7	`test_cvss_tek_basina_karari_belirlemez` (test_lab5_vuln)	✔ geçti

#	Test (dosya)	Sonuç
8	`test_bagimsiz_emniyette_plc_acigi_uretimi_durdurmaz` (test_lab5_vuln)	✔ geçti
9	`test_bagimli_emniyette_istismar_belirtisi_varsa_hat_kontrollu_durur` (test_lab5_vuln)	✔ geçti
10	`test_telafi_plani_acigi_ulasilamaz_kilar_ve_azami_surede_biter` (test_lab5_vuln)	✔ geçti
11	`test_plc_yamasi_validasyonu_yalniz_bagimli_mimaride_etkiler` (test_lab5_vuln)	✔ geçti
12	`test_emniyet_rolesi_degisikligi_her_mimaride_validasyon_gerektirir` (test_lab5_vuln)	✔ geçti
13	`test_yama_once_test_tezgahinda_denenir` (test_lab5_vuln)	✔ geçti (2/2)

Yorum: En önemli bulgu, LAB 4'teki emniyet bağımsızlığının zafiyet yönetimini de değiştirmesi. Bağımlı mimaride kritik bir PLC açığı hem acil telafi hem de yeniden doğrulama gerektiriyor. Bağımsız mimaride aynı açık, planlı bir bakım işine dönüşüyor.

Ek sorular: zafiyetler ve nasıl kapatılır

> Föy dışıdır; kullanıcı isteğiyle eklendi. Öneriler genel sektör pratiğidir; Efo'nun bunları uygulayıp uygulamadığı bilinmiyor.

E1 CRA, Efo'dan SBOM ve yama konusunda ne istiyor?

- **Durum:** Efo dijital eleman (PLC, HMI, invertör) içeren makineleri AB pazarına arz ediyorsa, CRA'nın üretici yükümlülükleri kapsamına girebilir ÇIKARIM.
- **İstenenler:**
  - Teknik dosyada bir SBOM.
  - Destek süresi boyunca ücretsiz güvenlik güncellemesi; rapor en az 5 yıl diyor [R16].
  - Aktif olarak istismar edilen zafiyetler için 24 sa / 72 sa / 14 gün bildirim; 11.09.2026'dan beri geçerli [Y20, Y22].
- **Kapatma:** Her makine için teslimatta bir SBOM (bileşen, sürüm, tedarikçi). Tedarikçi güvenlik bildirimlerine (Siemens ProductCERT, CISA ICS) abonelik. Müşteriye hangi kurulumun hangi sürümde olduğunu gösteren bir kayıt [Y23] SEKTÖR-TİPİK.

E2 SBOM'un güncel kalmaması bir zafiyet midir?

- **Zafiyet:** Sahada yapılan her firmware güncellemesi, parça değişimi ya da uzak masaüstü aracı kurulumu SBOM'u eskitir. Eski bir SBOM'la yapılan üç şart kontrolü yanlış "etkilemez" sonucu verir ÇIKARIM.
- **Kapatma:** SBOM'u değişiklik yönetimine bağlamak: her değişiklikte güncellenir ve yeni CRC ile birlikte kaydedilir. Etkilemeyen kayıtları gerekçesiyle (ör. "web sunucusu kapalı") kaydetmek. Durum değişirse karar yeniden açılır SEKTÖR-TİPİK.

E3 Yaması hiç gelmeyecek (ömrü bitmiş) bir bileşen varsa?

- **Zafiyet:** Eski bir HMI işletim sistemi ya da üretimi durmuş bir router için yama gelmez; telafi edici önlem kalıcı hâle gelir.
- **Kapatma:** Bileşeni kendi bölgesine almak (LAB 2) ve yalnızca gerekli akışlara izin vermek. Değiştirme planını bütçelemek. Ömrü biten bileşeni SBOM'da işaretlemek [Y26] SEKTÖR-TİPİK.

Ek — Kod

efo_sim/lab5_vuln.py

```
"""LAB 5 — SBOM / CVE / yama kararı (eğitim amaçlı).

5.1 Üç şart: bileşen SBOM'da var mı, sürüm etkileniyor mu, açık ulaşılabilir mi?
    Ulaşılabilirlik LAB 4 saldırı grafından hesaplanır (giriş noktalarından o düğüme yol var mı).
5.2 Karar akışı: üretim durur mu, yama nerede test edilir, emniyet validasyonu etkilenir mi,
    yama yoksa hangi telafi edici önlemler açığı kapatır?

Çalıştırma (repo kökünden):  python -m efo_sim.lab5_vuln
"""
```

```python
from itertools import combinations

from efo_sim import lab4_attack as lab4
from efo_sim.params import OUT_DIR, bolum_metni, d, sayi

MIMARILER = {
    "mevcut": ("Mevcut (varsayım)", lab4.MEVCUT | {"plc_web_sunucusu_acik": d("lab5.plc_web_sunucusu")["mevcut"]}
),
    "hedef": ("Hedef, içeri girilmiş kabulü",
              lab4.HEDEF_ICERI_GIRILDI | {"plc_web_sunucusu_acik": d("lab5.plc_web_sunucusu")["hedef"]}),
}
KARARLAR = {
    "devam": "Devam: CVE bu hatta etkili değil",
    "devam_telafi": "Devam + planlı telafi; yama bakım penceresinde",
    "hemen_telafi": "Durdurmadan hemen telafi; yama test sonrası",
    "durdur": "Kontrollü durdur; telafi ya da yama sonrası yeniden doğrula",
}


def sbom():
    return {b["id"]: b for b in d("lab5.sbom")}


def kayit(kayit_id):
    return next(k for k in d("lab5.kayitlar") if k["id"] == kayit_id)


def surum(metin):
    return tuple(int(p) for p in metin.split("."))


def surum_etkileniyor(mevcut, ilk_duzeltilmis):
    """İlk düzeltilmiş sürümden önceki her sürüm etkilenir."""
    if mevcut == "-" or ilk_duzeltilmis == "-":
        return False
    return surum(mevcut) < surum(ilk_duzeltilmis)


# ---------------------------------------------------------------- 5.1 Üç şart
def bilesen(k):
    """Kayıttaki ürün SBOM'daki hangi bileşen? Yoksa None."""
    return next((b for b in sbom().values() if b["urun"] == k["urun"]), None)


def uc_sart(k, mimari):
    b = bilesen(k)
    var = b is not None
    etkilenir = var and surum_etkileniyor(b["surum"], k["ilk_duzeltilmis"])
    ulasilir = var and b["dugum"] in lab4.ulasilabilir(mimari) and all(mimari[c] for c in k["ek_kosullar"])
    return {"var": var, "surum": etkilenir, "ulasilabilir": ulasilir}


def etkiler(k, mimari):
    return all(uc_sart(k, mimari).values())


# ---------------------------------------------------------------- 5.2 Karar akışı
def emniyete_yol(dugum, mimari):
    """Bu düğüm ele geçirilirse emniyet fonksiyonuna (LAB 4 grafı) yol var mı?"""
    return dugum == lab4.HEDEF_DUGUM or bool(lab4.yollar(mimari, dugum))


def validasyon_etkilenir(b, mimari):
    """Yama emniyet fonksiyonunun davranışını değiştirebilir mi? Evet ise yeniden doğrulama gerekir."""
    return b["dugum"] == "emniyet" or emniyete_yol(b["dugum"], mimari)


def telafi_plani(k, mimari):
    """Açığı ulaşılamaz kılan en kısa süreli önlem kümesi (bütün alt kümeler denenir)."""
    onlemler = [t for t in d("lab5.telafi_onlemleri") if mimari.get(t["kosul"])]
    adaylar = []
    for n in range(1, len(onlemler) + 1):
        for kume in combinations(onlemler, n):
            m = mimari | {t["kosul"]: False for t in kume}
            if not etkiler(k, m):
                adaylar.append((sum(t["saat"] for t in kume), len(kume), kume))
    if not adaylar:
        return None
```

```
    sure, _, kume = min(adaylar, key=lambda a: (a[0], a[1]))
    return {"onlemler": [t["id"] for t in kume], "saat": sure}


def uretim_karari(k, mimari, istismar_belirtisi=False):
    if not etkiler(k, mimari):
        return "devam"
    b = bilesen(k)
    if not emniyete_yol(b["dugum"], mimari):
        return "devam_telafi"
    plan = telafi_plani(k, mimari)
    if istismar_belirtisi or plan is None or plan["saat"] > d("lab5.telafi_azami_sure"):
        return "durdur"
    return "hemen_telafi"


def yama_adimlari(k, mimari):
    """Yama doğrudan uygulanmaz: önce test. Validasyon etkileniyorsa emniyet testleri eklenir."""
    adimlar = ["Yedek CPU'lu test tezgâhında aynı firmware + proje ile yamayı uygula",
               "Normal fonksiyon testleri (start/stop, interlock, haberleşme)"]
    b = bilesen(k)
    if b and validasyon_etkilenir(b, mimari):
        adimlar.append("Emniyet fonksiyonu testleri: SF1–SF4 + durma süresi ölçümü (LAB 1)")
    adimlar += ["Bakım penceresinde hatta uygula; eski sürümün yedeği hazır",
                "Konfigürasyon CRC'sini yeni referans olarak kaydet"]
    return adimlar


# ---------------------------------------------------------------- Çıktılar
def _evet(x):
    return "✓" if x else "X"


def sbom_md():
    s = ["| Bileşen | Sürüm | LAB 4 düğümü | Yazılım içerir |", "|---|---|---|---|"]
    for b in sbom().values():
        s.append(f"| {b['ad']} | {b['surum']} | {lab4.DUGUMLER[b['dugum']]} | {'evet' if b['yazilim'] else 'hayır
'} |")
    return "\n".join(s) + "\n"


def karar_md():
    s = ["| Kayıt | CVSS | Mimari | Bileşen var | Sürüm etkilenir | Ulaşılabilir | Emniyete yol | Karar |",
         "|---|---|---|---|---|---|---|---|"]
    for k in d("lab5.kayitlar"):
        b = bilesen(k)
        for anahtar, (ad, m) in MIMARILER.items():
            u = uc_sart(k, m)
            yol = _evet(emniyete_yol(b["dugum"], m)) if b else "—"
            s.append(f"| {k['cve']} ({k['urun']}) | {sayi(k['cvss'], 1)} | {ad} | {_evet(u['var'])} | "
                     f"{_evet(u['surum'])} | {_evet(u['ulasilabilir'])} | {yol} | {KARARLAR[uretim_karari(k,
m)]} |")
    s += ["", "Ulaşılabilirlik, LAB 4'teki giriş noktalarından (internet, uzak araç, USB, yerel HMI, Wi-Fi) "
              "bileşenin düğümüne açık bir yol olup olmadığıdır. Hedef sütununda saldırganın VPN ve MFA'yı "
              "aştığı kabul edildi."]
    return "\n".join(s) + "\n"


def telafi_md():
    onlem = {t["id"]: t for t in d("lab5.telafi_onlemleri")}
    k = kayit("FOY-X")
    s = ["| Mimari | En kısa telafi kümesi | Süre | Telafiden sonra ulaşılabilir mi? | Validasyon etkilenir mi?
|",
         "|---|---|---|---|---|"]
    for ad, m in MIMARILER.values():
        p = telafi_plani(k, m)
        if p is None:
            s.append(f"| {ad} | bulunamadı | — | evet | — |")
            continue
        m2 = m | {onlem[i]["kosul"]: False for i in p["onlemler"]}
        kume = "<br>".join(f"{i}: {onlem[i]['ad']}" for i in p["onlemler"])
        s.append(f"| {ad} | {kume} | {sayi(p['saat'])} sa | {'evet' if etkiler(k, m2) else 'hayır'} | "
                 f"{'**evet**' if validasyon_etkilenir(bilesen(k), m) else 'hayır'} |")
    s += ["", f"Telafi için kabul edilen azami süre: {sayi(d('lab5.telafi_azami_sure'), 1)} saat. "
              "Aktif istismar belirtisi varsa ve bileşenden emniyet fonksiyonuna yol varsa karar doğrudan "
              f"\"{KARARLAR['durdur']}\" olur."]
    return "\n".join(s) + "\n"

```

```
def main():
    OUT_DIR.mkdir(exist_ok=True)
    (OUT_DIR / "lab5_sbom.md").write_text(sbom_md(), encoding="utf-8")
    (OUT_DIR / "lab5_karar.md").write_text(karar_md(), encoding="utf-8")
    (OUT_DIR / "lab5_telafi.md").write_text(telafi_md(), encoding="utf-8")
    (OUT_DIR / "lab5_params.yaml").write_text(bolum_metni("lab5"), encoding="utf-8")
    print(karar_md())
    print(telafi_md())


if __name__ == "__main__":
    main()
```

efo_sim/tests/test_lab5_vuln.py

```
"""LAB 5 gereksinimleri = testler (eğitim amaçlı model)."""
import pytest

from efo_sim import lab5_vuln as m

MEVCUT = m.MIMARILER["mevcut"][1]
HEDEF = m.MIMARILER["hedef"][1]


# ---------------------------------------------------------------- 5.1 Üç şart
@pytest.mark.parametrize("mevcut,duzeltilmis,beklenen", [
    ("2.4", "2.5", True), ("2.5", "2.5", False), ("2.10", "2.5", False),
    ("4.5", "4.7", True), ("4.7", "4.7", False), ("-", "2.5", False),
])
def test_surum_karsilastirmasi_sayisaldir(mevcut, duzeltilmis, beklenen):
    assert m.surum_etkileniyor(mevcut, duzeltilmis) is beklenen


def test_foydeki_kayit_mevcut_mimaride_uc_sarti_da_saglar():
    assert m.uc_sart(m.kayit("FOY-X"), MEVCUT) == {"var": True, "surum": True, "ulasilabilir": True}


def test_sbomda_olmayan_urun_cvss_yuksek_olsa_da_etkilemez():
    k = m.kayit("SSA-688146")
    assert k["cvss"] >= 9.0
    assert not m.uc_sart(k, MEVCUT)["var"]
    assert m.uretim_karari(k, MEVCUT) == "devam"


def test_web_sunucusu_kapaliysa_csrf_acigi_ulasilamaz():
    k = m.kayit("CVE-2024-47100")
    assert m.etkiler(k, MEVCUT)
    assert m.uc_sart(k, HEDEF)["surum"] and not m.uc_sart(k, HEDEF)["ulasilabilir"]


def test_her_sbom_bileseni_saldiri_grafinda_bir_dugume_baglidir():
    for b in m.sbom().values():
        assert b["dugum"] in m.lab4.DUGUMLER


def test_telafi_onlemleri_mimarideki_kosullari_kapatir():
    for t in m.d("lab5.telafi_onlemleri"):
        assert t["kosul"] in MEVCUT and t["kosul"] in HEDEF


# ---------------------------------------------------------------- 5.2 Karar akışı
def test_cvss_tek_basina_karari_belirlemez():
    """Aynı 9,8'lik kayıt mimariye göre farklı karar alır."""
    k = m.kayit("FOY-X")
    assert m.uretim_karari(k, MEVCUT) != m.uretim_karari(k, HEDEF)


def test_bagimsiz_emniyette_plc_acigi_uretimi_durdurmaz():
    assert m.uretim_karari(m.kayit("FOY-X"), HEDEF) == "devam_telafi"


def test_bagimli_emniyette_istismar_belirtisi_varsa_hat_kontrollu_durur():
    assert m.uretim_karari(m.kayit("FOY-X"), MEVCUT, istismar_belirtisi=True) == "durdur"


def test_telafi_plani_acigi_ulasilamaz_kilar_ve_azami_surede_biter():
    k = m.kayit("FOY-X")
```

```
    onlem = {t["id"]: t for t in m.d("lab5.telafi_onlemleri")}
    for _, mim in m.MIMARILER.values():
        p = m.telafi_plani(k, mim)
        assert p is not None and p["saat"] <= m.d("lab5.telafi_azami_sure")
        assert not m.etkiler(k, mim | {onlem[i]["kosul"]: False for i in p["onlemler"]})


def test_plc_yamasi_validasyonu_yalniz_bagimli_mimaride_etkiler():
    plc = m.sbom()["PLC_FW"]
    assert m.validasyon_etkilenir(plc, MEVCUT)
    assert not m.validasyon_etkilenir(plc, HEDEF)


def test_emniyet_rolesi_degisikligi_her_mimaride_validasyon_gerektirir():
    role = m.sbom()["EMNIYET_RELE"]
    assert m.validasyon_etkilenir(role, MEVCUT) and m.validasyon_etkilenir(role, HEDEF)


@pytest.mark.parametrize("mimari", ["mevcut", "hedef"])
def test_yama_once_test_tezgahinda_denenir(mimari):
    adimlar = m.yama_adimlari(m.kayit("FOY-X"), m.MIMARILER[mimari][1])
    assert "test tezgâhı" in adimlar[0]
    emniyet_testi = any("SF1" in a for a in adimlar)
    assert emniyet_testi is (mimari == "mevcut")
```

`params.yaml` — LAB 5 bölümü:

efo_sim/out/lab5_params.yaml

```
lab5:
  # SBOM: hat yazılım bileşenleri. "dugum" = LAB 4 saldırı grafındaki karşılığı
  sbom:
    deger:
      - {id: PLC_FW, ad: "PLC firmware (S7-1200 sınıfı)", urun: "S7-1200", dugum: plc, surum: "4.5", yazilim: true}
      - {id: COMP_X, ad: "Component X (PLC firmware kütüphanesi)", urun: "Component X", dugum: plc, surum: "2.4", yazilim: true}
      - {id: HMI_SW, ad: "Operatör paneli yazılımı", urun: "HMI runtime", dugum: hmi, surum: "17.0", yazilim: true}
      - {id: UZAK_ARAC, ad: "Uzak masaüstü aracı (HMI'da)", urun: "Uzak masaüstü", dugum: hmi, surum: "15.0", yazilim: true}
      - {id: VFD_FW, ad: "Bant invertörü firmware + WLAN modülü", urun: "VFD", dugum: vfd, surum: "3.2", yazilim: true}
      - {id: ROUTER_FW, ad: "4G/VPN router firmware", urun: "4G router", dugum: router, surum: "7.1", yazilim: true}
      - {id: EMNIYET_RELE, ad: "Emniyet rölesi (kablolu, yazılımsız)", urun: "Emniyet rölesi", dugum: emniyet, surum: "-", yazilim: false}
    etiket: "VARSAYIM"
    kaynak: "V2, V3, V5, V16"
    not: "Efo SBOM yayınlamıyor. Bileşenler LAB 2 varlık listesinden; sürümler kabul. Component X ve 2.4 föyden"

  # Zafiyet kayıtları: föydeki kayıt + iki gerçek kayıt (karşılaştırma için)
  kayitlar:
    deger:
      - {id: FOY-X, cve: "CVE-XXXX-XXXX", urun: "Component X", ilk_duzeltilmis: "2.5", cvss: 9.8,
         vektor: "ağ (kimlik doğrulamasız)", ek_kosullar: [], yama: "2.5", kaynak: "föy LAB 5 + V17"}
      - {id: CVE-2024-47100, cve: "CVE-2024-47100", urun: "S7-1200", ilk_duzeltilmis: "4.7", cvss: 7.1,
         vektor: "ağ, PLC web arayüzü (CSRF, kullanıcı etkileşimi)", ek_kosullar: [plc_web_sunucusu_acik], yama: "4.7", kaynak: "Y12"}
      - {id: SSA-688146, cve: "SSA-688146", urun: "S7-1500 / ET 200SP", ilk_duzeltilmis: "-", cvss: 9.1,
         vektor: "ağ", ek_kosullar: [], yama: "üretici bildirimine göre", kaynak: "Y14"}
    etiket: "SEKTÖR-TİPİK"
    kaynak: "föy LAB 5, Y12, Y14"
    not: "FOY-X'in etkilenen sürüm aralığı föyde yok; 2.5 öncesi etkilenir kabul edildi (V17)"

  # LAB 4 mimarilerine eklenen koşul
  plc_web_sunucusu:
    deger: {mevcut: true, hedef: false}
    etiket: "VARSAYIM"
    kaynak: "V13"
    not: "Mevcutta PLC web sunucusu açık; hedefte kapalı"

  # Telafi edici önlemler: kapattığı koşul (LAB 4 mimari anahtarı) ve uygulama süresi
  telafi_onlemleri:
    deger:
      - {id: T1, ad: "Uzak destek router'ının bağlantısını fiziksel olarak kesmek", kosul: router_surekli_acik, saat: 0.25}
      - {id: T2, ad: "PLC web sunucusunu kapatmak", kosul: plc_web_sunucusu_acik, saat: 1.0}
```

```
      - {id: T3, ad: "İnvertör WLAN modülünü sökmek", kosul: wlan_modulu_acik, saat: 0.25}
      - {id: T4, ad: "Pano ve HMI USB portlarını kilitlemek", kosul: usb_kilitsiz, saat: 0.5}
      - {id: T5, ad: "HMI varsayılan parolasını değiştirmek", kosul: hmi_varsayilan_parola, saat: 0.25}
      - {id: T6, ad: "HMI'daki uzak masaüstü aracını kaldırmak", kosul: uzak_masaustu_kurulu, saat: 0.5}
      - {id: T7, ad: "Yama bitene kadar uzak bakım oturumuna (C1) tesis onayı vermemek", kosul: uzak_oturum_acik,
saat: 0.1}
    etiket: "VARSAYIM"
    kaynak: "V18, Y15"
    not: "Süreler bir bakım teknisyeni için kaba tahmin"
  telafi_azami_sure:
    {deger: 2.0, birim: "saat", etiket: "VARSAYIM", kaynak: "V18",
     not: "Emniyete yol açan bir zafiyette telafi bu süre içinde bitirilemiyorsa hat kontrollü durdurulur"}
```

pytest çıktısı:

efo_sim/out/pytest_lab5.txt

```
============================= test session starts ==============================
platform linux -- Python 3.14.8, pytest-9.0.2, pluggy-1.6.0 -- /usr/bin/python
rootdir: /home/ydogan/Masaüstü/safety40-efo-konveyor
configfile: pytest.ini
plugins: asyncio-1.3.0, anyio-4.13.0
asyncio: mode=Mode.STRICT, debug=False, asyncio_default_fixture_loop_scope=None,
asyncio_default_test_loop_scope=function
collecting ... collected 19 items

efo_sim/tests/test_lab5_vuln.py::test_surum_karsilastirmasi_sayisaldir[2.4-2.5-True] PASSED [  5%]
efo_sim/tests/test_lab5_vuln.py::test_surum_karsilastirmasi_sayisaldir[2.5-2.5-False] PASSED [ 10%]
efo_sim/tests/test_lab5_vuln.py::test_surum_karsilastirmasi_sayisaldir[2.10-2.5-False] PASSED [ 15%]
efo_sim/tests/test_lab5_vuln.py::test_surum_karsilastirmasi_sayisaldir[4.5-4.7-True] PASSED [ 21%]
efo_sim/tests/test_lab5_vuln.py::test_surum_karsilastirmasi_sayisaldir[4.7-4.7-False] PASSED [ 26%]
efo_sim/tests/test_lab5_vuln.py::test_surum_karsilastirmasi_sayisaldir[--2.5-False] PASSED [ 31%]
efo_sim/tests/test_lab5_vuln.py::test_foydeki_kayit_mevcut_mimaride_uc_sarti_da_saglar PASSED [ 36%]
efo_sim/tests/test_lab5_vuln.py::test_sbomda_olmayan_urun_cvss_yuksek_olsa_da_etkilemez PASSED [ 42%]
efo_sim/tests/test_lab5_vuln.py::test_web_sunucusu_kapaliysa_csrf_acigi_ulasilamaz PASSED [ 47%]
efo_sim/tests/test_lab5_vuln.py::test_her_sbom_bileseni_saldiri_grafinda_bir_dugume_baglidir PASSED [ 52%]
efo_sim/tests/test_lab5_vuln.py::test_telafi_onlemleri_mimarideki_kosullari_kapatir PASSED [ 57%]
efo_sim/tests/test_lab5_vuln.py::test_cvss_tek_basina_karari_belirlemez PASSED [ 63%]
efo_sim/tests/test_lab5_vuln.py::test_bagimsiz_emniyette_plc_acigi_uretimi_durdurmaz PASSED [ 68%]
efo_sim/tests/test_lab5_vuln.py::test_bagimli_emniyette_istismar_belirtisi_varsa_hat_kontrollu_durur PASSED [ 73%]
efo_sim/tests/test_lab5_vuln.py::test_telafi_plani_acigi_ulasilamaz_kilar_ve_azami_surede_biter PASSED [ 78%]
efo_sim/tests/test_lab5_vuln.py::test_plc_yamasi_validasyonu_yalniz_bagimli_mimaride_etkiler PASSED [ 84%]
efo_sim/tests/test_lab5_vuln.py::test_emniyet_rolesi_degisikligi_her_mimaride_validasyon_gerektirir PASSED [ 89%]
efo_sim/tests/test_lab5_vuln.py::test_yama_once_test_tezgahinda_denenir[mevcut] PASSED [ 94%]
efo_sim/tests/test_lab5_vuln.py::test_yama_once_test_tezgahinda_denenir[hedef] PASSED [100%]

============================== 19 passed in 0.05s ==============================
```

Kaynaklar

R = derin araştırma raporundaki kaynak numarası; Y = bu çalışmada eklenen kaynak.

- **R16** Knapster — Cyber Resilience Act: Deadlines — https://www.knapster.at/en/wissen/cyber-resilience-act-fristen-produktklassen.html
- **R61** IEC 61508 Functional Safety — SIL, PFD, Safety PLC — https://iotdigitaltwinplm.com/iec-61508-functional-safety-sil-pfd-safety-instrumented-systems-safety-plc-architecture-2026/
- **Y12** CISA ICSA-25-021-02 — Siemens SIMATIC S7-1200 CPUs (CVE-2024-47100) — https://cisa.gov/news-events/ics-advisories/icsa-25-021-02
- **Y14** Siemens ProductCERT SSA-688146 — https://cert-portal.siemens.com/productcert/html/ssa-688146.html
- **Y20** The Cyber Resilience Act Explained — https://www.cyberresilienceact.eu/explained.html
- **Y22** Regulation (EU) 2024/2847 (Cyber Resilience Act), Article 14 — Reporting obligations of manufacturers — https://eur-lex.europa.eu/eli/reg/2024/2847/oj
- **Y23** CISA — Software Bill of Materials (SBOM) — https://www.cisa.gov/sbom
- **Y24** FIRST — CVSS v3.1 Specification Document — https://www.first.org/cvss/v3.1/specification-document
- **Y25** CISA — Known Exploited Vulnerabilities Catalog — https://www.cisa.gov/known-exploited-vulnerabilities-catalog
- **Y26** NIST SP 800-82 Rev. 3 — Guide to Operational Technology (OT) Security — https://csrc.nist.gov/pubs/sp/800/82/r3/final